VULNERABILITY ASSESSMENT REPORT

REPORT ON: https://professionaljobcentre.gpg.gov.za/

BY LETSOALE KGOPOTSO

20 MARCH 2026

TABLE OF CONTENTS

BACKGROUND & ENGAGEMENT 1

SCOPE AND ETHICAL BOUNDARIES 3

THE TECHNICAL TOOLBOX 6

CVSS (COMMON VULNERABILITY SCORING SYSTEM) 7

INITIAL OBSERVATION AND SERVICE FAILURE 9

TECHNICAL EXECUTION: RECONNAISSANCE & DISCOVERY 11

VULNERABILITY: SERVICE FINGERPRINTING & INFORMATION DISCLOSURE 15

PRACTICAL BUSINESS FIXES HEADER SUPPRESSION 19

HTTP SECURITY HEADER & BROWSER HARDENING AUDIT 21

ASSESSMEENT METHODOLOGY 23

Background & Engagement

On the 20th of March 2026, I recognized that there was a total service failure at the GPG Professional Job Centre web portal, as indicated by a Server Error in or Application. Recognizing the significance of this web portal to the people of South Africa, I conducted an unsolicited security audit in an attempt to assist in identifying the exact cause of the problem.

As an independent researcher, I have conducted a Read-Only Vulnerability Assessment in an attempt to give the GPG IT department a clear idea of the exact cause of the problem and the underlying security threats, including End-of-Life software and missing headers, which are responsible for the total service failure and which are preventing a successful recovery.

DISCLOSURE NOTICE

I have written this document in my capacity as an Independent Security Researcher. This document has been written in the absence of any formal involvement by the Gauteng Provincial Government.

This document has been written in the spirit of Ethical Disclosure. No systems have been compromised, no data infiltrated and no exploitation attempted. This document is written in the hopes of helping the GPG team further tighten their systems against all existing threats.

SCOPE AND ETHICAL BOUNDARIES

This evaluation was performed entirely from an external Black Box perspective. As no Rules of Engagement were previously defined, I adhered to the Passive Testing Methodology. This means:

- No Brute Force attacks were attempted.
- No Denial of Service (DoS) attacks were attempted.
- No Exploitation of the system occurred, although i recognized the vulnerabilities, they were not traversed

The results presented below are low-hanging fruit that any malicious user would be aware of. I provide this report out of courtesy to assit in the restoratin of public services.

The Phases of my Assessment

Phase 1

Discovery– Initial observation of the Server Error and SSL/TLS Certificate Warning

Phase 2

Port Scanning – Using Nmap to identify service banners without disrupting traffic.

Phase 3

Service Fingerprinting - Identifying that this server was using Microsoft-IIS 10.0 and ASP.NET 4.0.

Phase 4

Vulnerability Analysis– Identifying that this version of ASP.NET was End-of-Life and was the reason for this system's instability.

Idependent External Assessment:

This process of assessment emulated the Reconnaissance phase of the cyber-attack. I played the role of an outside observer with zero inside knowledge and access to the GPG internal network. I was required to identify the Public Facing Risks that any individual on the Internet could identify.

I focused on the Technical Fingerprinting and the Configuration Auditing to identify the reasons for the failure of the portal and how this could be exploited by the cyber criminal to steal citizen information.

The Technical Toolbox

- Kali Linux : An industry-standard operating system used for advanced security auditing and penetration testing.
- Nmap (Network Mapper): Used for Service Fingerprinting, which identifies the open communication ports and the versions of the running applications.
- Browser Developer Tools (DevTools): Used to perform a Header Audit, which identifies the absence of security instructions which protect the citizen data.
- OSINT (Open Source Intelligence): Used to verify the versions of the running applications with the global vulnerability databases.

CVSS (Common Vulnerability Scoring System)

Severity	Risk Impact	Action Required
High	**Direct System Compromise** can lead to full server takeover or huge data leaks	**Fix Immediately**. Stop all other work to fix this.
High	**Data Loss or Service outage.** Exploitation is probable and can result in website crash.	**Fix within 24 – 27 hours.** High priority for the IT team.
Medium	**Limited Exploitation.** Needs additional work for an attacker to study the site.	**Fix within 30 days**. After High-priority items.
Low	**Information Leakage** Not a direct hack but allows an attacker to study the site.	**Fix during maintenance.** Improves overall site.
Info	**Security Best Practices.** General observation to improve site health	**Review and Implement** when possible.

The ID Card for my project

- Assessment Type: Vulnerability Assassment Report (Read-Only)
- Target URL: https://professionaljobcentre.gpg.gov.za/
- Primary Issue: System-wide Server Error and SSL/TLS instability.
- Testing Window: March 18 – March 21 2026.

BASELINE ASSESSMENT

When accessing the Gauteng Professional Job Centre portal, it was found that the service is totally unavailable, with a Server Error page being displayed instead of a login prompt. This means that the service is totally unavailable to South African users.

WHY THIS IS A SECURITY RISK?

The error page provides too much detail that is needed by the hacker in order to plan an attack

Database Leak: The page leaks that the website cannot connect to Microsoft SQL Server.

Folder Leak: The page leaks the file paths of the website, which are stored locally on the developer's computer.

Permission Leak: The Access is Denied message "leaks" that there is something wrong with the permissions on the website.

INITIAL OBSERVATION AND SERVICE FAILURE

RISK LEVEL: HIGH

WService Impact: The website is 100% unavailable.

Information Disclosure: The website discloses its internal structure to a hacker.

Server Error in '/' Application.

Access is denied

Description: An unhandled exception occurred during the execution of the current web request. Please review the stack trace for more information about the error and where it originated in the code.

Exception Details: System.ComponentModel.Win32Exception: Access is denied

Source Error:

```
An unhandled exception was generated during the execution of the current web request. Information regarding the origin and location of the exception can be identified using the exception stack trace below.
```

Stack Trace:

```
[Win32Exception (0x80004005): Access is denied]

[SqlException (0x80131904): A network-related or instance-specific error occurred while establishing a connection to SQL Server. The server was not found or wa
   System.Data.ProviderBase.DbConnectionPool.TryGetConnection(DbConnection owningObject, UInt32 waitForMultipleObjectsTimeout, Boolean allowCreate, Boolean onl
   System.Data.ProviderBase.DbConnectionPool.TryGetConnection(DbConnection owningObject, TaskCompletionSource`1 retry, DbConnectionOptions userOptions, DbConne
   System.Data.ProviderBase.DbConnectionFactory.TryGetConnection(DbConnection owningConnection, TaskCompletionSource`1 retry, DbConnectionOptions userOptions,
   System.Data.ProviderBase.DbConnectionInternal.TryOpenConnectionInternal(DbConnection outerConnection, DbConnectionFactory connectionFactory, TaskCompletionS
   System.Data.ProviderBase.DbConnectionClosed.TryOpenConnection(DbConnection outerConnection, DbConnectionFactory connectionFactory, TaskCompletionSource`1 re
```

Figure 1: Image of the website

I.Technical Execution: Reconnaissance & Discovery

```
Session  Actions  Edit  View  Help
┌──(kgopotso21㉿kali-linux)-[~]
└─$ pinf -c 4 professionaljobcentre.gpg.gov.za
Command 'pinf' not found, did you mean:
  command 'ping' from deb inetutils-ping
  command 'ping' from deb iputils-ping
  command 'pinfo' from deb pinfo
Try: sudo apt install <deb name>

┌──(kgopotso21㉿kali-linux)-[~]
└─$ ping -c 4 professionaljobcentre.gpg.gov.za
PING waws-prod-jnb21-005.southafricanorth.cloudapp.azure.com (102.133.250.160
) 56(84) bytes of data.
64 bytes from 102.133.250.160: icmp_seq=1 ttl=255 time=102 ms
64 bytes from 102.133.250.160: icmp_seq=2 ttl=255 time=124 ms
64 bytes from 102.133.250.160: icmp_seq=3 ttl=255 time=46.7 ms
64 bytes from 102.133.250.160: icmp_seq=4 ttl=255 time=68.6 ms

--- waws-prod-jnb21-005.southafricanorth.cloudapp.azure.com ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3001ms
rtt min/avg/max/mdev = 46.654/85.405/124.451/29.931 ms

┌──(kgopotso21㉿kali-linux)-[~]
└─$ nmap professionaljobcentre.gpg.gov.za
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-20 13:13 SAST
Nmap scan report for professionaljobcentre.gpg.gov.za (102.133.250.160)
Host is up (0.050s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
48080/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 8.59 seconds

┌──(kgopotso21㉿kali-linux)-[~]
└─$
```

figure 2: image of connectivity test using ping -c 4

The Initial Handshake (Ping)

Before diving into deep scanning, I initiated a Connectivity Test using the ping -c 4 command. In the terminal below, you can see the results of this echo request. I did this for two reasons. Firstly, to ensure that the server at 102.133.250.160 was actually alive and responding to traffic, even if the website was displaying a Server Error. Secondly, to ensure the time it takes for a signal to travel was reasonable. With a RTT of approximately 85ms, I was able to ensure a stable connection to the South African Azure Cloud host. This step is vital because it ensures the auditor is testing a live version of the site and not a cached version of the site.

The Infrastructure Audit (Nmap)

Once connectivity was confirmed, I was able to run a Network Map (Nmap) to determine the server's Attack Surface. I typed in the command nmap professionaljobcentre.gpg.gov.za, instructing my computer to scan for Exposed Services on the target server.

Critical Service Exposure & Protocol Risks

Severity	Risk Impact	Action Required
High	**Direct System Compromise** can lead to full server takeover or huge data leaks	**Fix Immediately**. Stop all other work to fix this.
High	**Data Loss or Service outage.** Exploitation is probable and can result in website crash.	**Fix within 24 – 27 hours.** High priority for the IT team.
Medium	**Limited Exploitation.** Needs additional work for an attacker to study the site.	**Fix within 30 days**. After High-priority items.
Low	**Information Leakage** Not a direct hack but allows an attacker to study the site.	**Fix during maintenance.** Improves overall site.
Info	**Security Best Practices.** General observation to improve site health	**Review and Implement** when possible.

2. Vulnerability: Service Fingerprinting & Information Disclosure

```
Session  Actions  Edit  View  Help

┌──(kgopotso21㉿kali-linux)-[~]
└─$ nmap -sv -p 80 ,443 ,8172 professionaljobcentre.jpq.gov.za
Nmap 7.95 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
  -p <port ranges>: Only scan specified ports
    Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
  --exclude-ports <port ranges>: Exclude the specified ports from scanning
  -F: Fast mode - Scan fewer ports than the default scan
  -r: Scan ports sequentially - don't randomize
  --top-ports <number>: Scan <number> most common ports
  --port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
  -sV: Probe open ports to determine service/version info
  --version-intensity <level>: Set from 0 (light) to 9 (try all probes)
  --version-light: Limit to most likely probes (intensity 2)
  --version-all: Try every single probe (intensity 9)
  --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
  -sC: equivalent to --script=default
  --script=<Lua scripts>: <Lua scripts> is a comma separated list of
           directories, script-files or script-categories
  --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
```

```
Session  Actions  Edit  View  Help
  --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
  -sC: equivalent to --script=default
  --script=<Lua scripts>: <Lua scripts> is a comma separated list of
           directories, script-files or script-categories
  --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
  --script-args-file=filename: provide NSE script args in a file
  --script-trace: Show all data sent and received
  --script-updatedb: Update the script database.
  --script-help=<Lua scripts>: Show help about scripts.
           <Lua scripts> is a comma-separated list of script-files or
           script-categories.
OS DETECTION:
  -O: Enable OS detection
  --osscan-limit: Limit OS detection to promising targets
  --osscan-guess: Guess OS more aggressively
TIMING AND PERFORMANCE:
  Options which take <time> are in seconds, or append 'ms' (milliseconds),
  's' (seconds), 'm' (minutes), or 'h' (hours) to the value (e.g. 30m).
  -T<0-5>: Set timing template (higher is faster)
  --min-hostgroup/max-hostgroup <size>: Parallel host scan group sizes
  --min-parallelism/max-parallelism <numprobes>: Probe parallelization
  --min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>: Specifies
      probe round trip time.
  --max-retries <tries>: Caps number of port scan probe retransmissions.
  --host-timeout <time>: Give up on target after this long
  --scan-delay/--max-scan-delay <time>: Adjust delay between probes
  --min-rate <number>: Send packets no slower than <number> per second
  --max-rate <number>: Send packets no faster than <number> per second
FIREWALL/IDS EVASION AND SPOOFING:
  -f; --mtu <val>: fragment packets (optionally w/given MTU)
  -D <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
  -S <IP_Address>: Spoof source address
  -e <iface>: Use specified interface
  -g/--source-port <portnum>: Use given port number
  --proxies <url1,[url2],...>: Relay connections through HTTP/SOCKS4 proxies
  --data <hex string>: Append a custom payload to sent packets
  --data-string <string>: Append a custom ASCII string to sent packets
  --data-length <num>: Append random data to sent packets
  --ip-options <options>: Send packets with specified ip options
  --ttl <val>: Set IP time-to-live field
  --spoof-mac <mac address/prefix/vendor name>: Spoof your MAC address
  --badsum: Send packets with a bogus TCP/UDP/SCTP checksum
OUTPUT:
  -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3,
     and Grepable format, respectively, to the given filename.
  -oA <basename>: Output in the three major formats at once
  -v: Increase verbosity level (use -vv or more for greater effect)
  -d: Increase debugging level (use -dd or more for greater effect)
  --reason: Display the reason a port is in a particular state
  --open: Only show open (or possibly open) ports
```

```
Session  Actions  Edit  View  Help
  --host-timeout <time>: Give up on target after this long
  --scan-delay/--max-scan-delay <time>: Adjust delay between probes
  --min-rate <number>: Send packets no slower than <number> per second
  --max-rate <number>: Send packets no faster than <number> per second
FIREWALL/IDS EVASION AND SPOOFING:
  -f; --mtu <val>: fragment packets (optionally w/given MTU)
  -D <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
  -S <IP_Address>: Spoof source address
  -e <iface>: Use specified interface
  -g/--source-port <portnum>: Use given port number
  --proxies <url1,[url2],...>: Relay connections through HTTP/SOCKS4 proxies
  --data <hex string>: Append a custom payload to sent packets
  --data-string <string>: Append a custom ASCII string to sent packets
  --data-length <num>: Append random data to sent packets
  --ip-options <options>: Send packets with specified ip options
  --ttl <val>: Set IP time-to-live field
  --spoof-mac <mac address/prefix/vendor name>: Spoof your MAC address
  --badsum: Send packets with a bogus TCP/UDP/SCTP checksum
OUTPUT:
  -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3,
     and Grepable format, respectively, to the given filename.
  -oA <basename>: Output in the three major formats at once
  -v: Increase verbosity level (use -vv or more for greater effect)
  -d: Increase debugging level (use -dd or more for greater effect)
  --reason: Display the reason a port is in a particular state
  --open: Only show open (or possibly open) ports
  --packet-trace: Show all packets sent and received
  --iflist: Print host interfaces and routes (for debugging)
  --append-output: Append to rather than clobber specified output files
  --resume <filename>: Resume an aborted scan
  --noninteractive: Disable runtime interactions via keyboard
  --stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
  --webxml: Reference stylesheet from Nmap.Org for more portable XML
  --no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
  -6: Enable IPv6 scanning
  -A: Enable OS detection, version detection, script scanning, and traceroute
  --datadir <dirname>: Specify custom Nmap data file location
  --send-eth/--send-ip: Send using raw ethernet frames or IP packets
  --privileged: Assume that the user is fully privileged
  --unprivileged: Assume the user lacks raw socket privileges
  -V: Print version number
  -h: Print this help summary page.
EXAMPLES:
  nmap -v -A scanme.nmap.org
  nmap -v -sn 192.168.0.0/16 10.0.0.0/8
  nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (https://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
Scantype v not supported
```

figure 3: images of Service Detection (-sV) scan

2. Vulnerability: Service Fingerprinting & Information Disclosure

After the initial discovery of the open port, I proceeded to conduct a Service Version Detection (-sV) scan. This step is important as it takes the knowledge of an open door to the next step of not only knowing the brand and model of the software listening to the door but also knowing the version of the software. My terminal was successful in fingerprinting the web server as running Microsoft IIS 10.0 on a Windows-based operating system. Although IIS 10.0 is a state-of-the-art application, the fact that the server is openly broadcasting this information is a vulnerability referred to as Service Banner Grabbing. In a real-life scenario, this would be categorized as Information Disclosure as it gives an intruder a roadmap to the target system. Since the intruder already knows the version of the operating system and the version of the server software, he or she wouldn't need to guess, he or she could immediately target exploits for the Windows Server and IIS 10.0 combination.

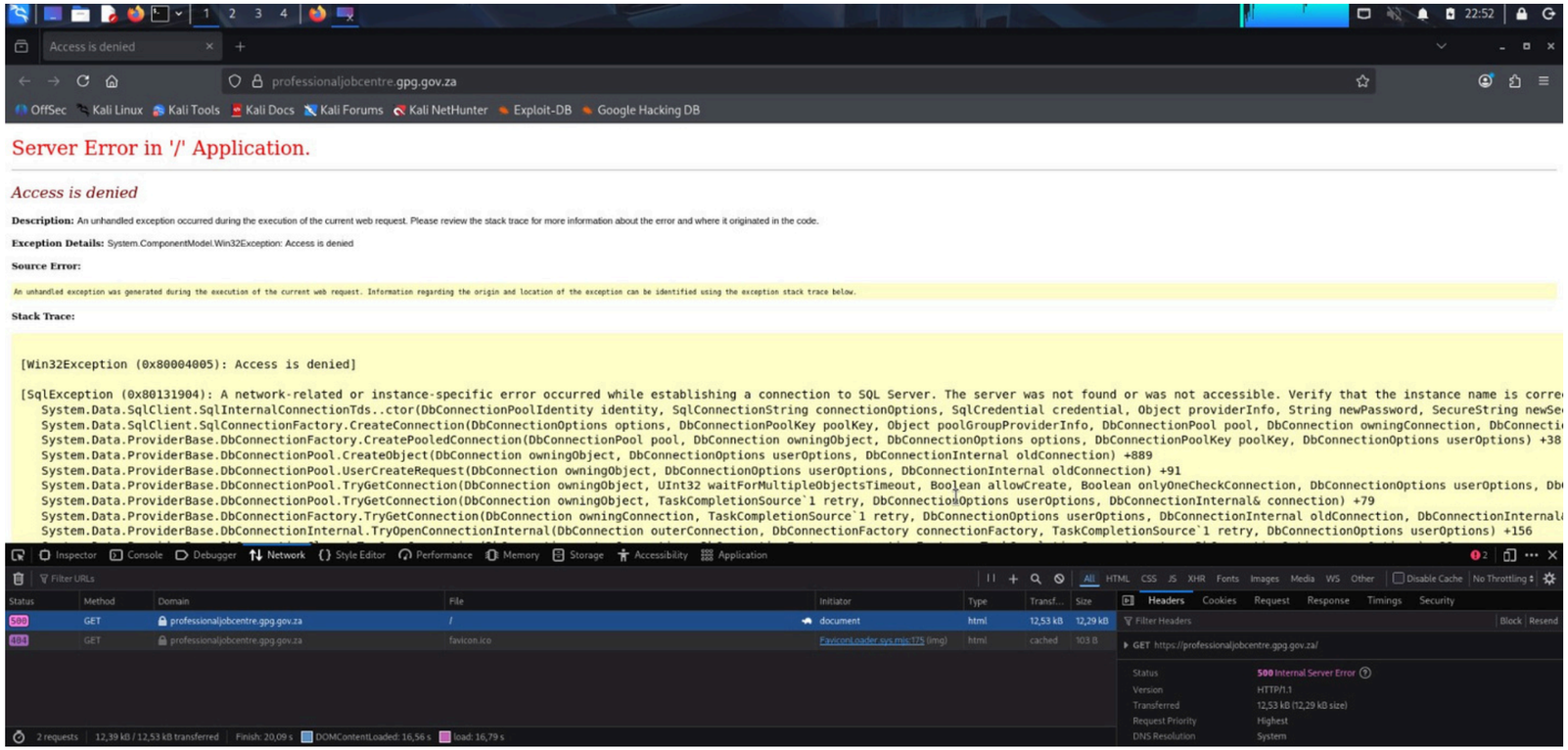
2. Vulnerability: Service Fingerprinting & Information Disclosure

Elements	Technical Finding
Identified Issue	Verbose Service Banners. The server is giving away its name (Microsoft-IIS/10.0) and Operating System (Windows) to any unauthorized scanner.
Why it Matters?	Reconnaissance Efficiency. The first step of an attacker's process is to 'fingerprint' the target. By giving away the exact software version, the server is making the attacker's job easier by allowing them to research specific CVEs (Common Vulnerabilities and Exposures) related to that version of the software.
Risk Level	Low
Risk Classification	Information Disclosure. This is not a direct entry point but reduces the overall security of the system by allowing an attacker to 'map' the environment.

Practical Business Fixes Header Suppression

- Configure the IIS server to remove the Server header from HTTP responses. The server should respond with a generic message rather than its specific version.
- Remove X-Powered-By Headers: Ensure that the X-Powered-By and X-AspNet-Version headers are disabled in the web.config file to hide the underlying framework details.
- Security through Obscurity: Implement "Least Information" policies. If the public doesn't need to know the OS version to use the site, the server shouldn't tell them.

3. HTTP Security Header & Browser Hardening Audit



Browser-Side Security Analysis

After identifying the server's open ports and software versions, I conducted a Header Audit using Browser Developer Tools. Security headers are instructions sent from the server to the user's browser to prevent common web attacks. My analysis revealed that the GPG Job Centre portal is currently operating without these essential 'Digital Bodyguards.' Specifically, the server is failing to utilize HSTS (Strict-Transport-Security) and CSP (Content-Security-Policy). By omitting these, the site misses the opportunity to use the browser's built-in security features to automatically block malicious scripts or forced unencrypted connections. This missing layer of defence significantly increases the risk of 'Man-in-the-Middle' (MitM) and 'Clickjacking' attacks against South African citizens using the portal.

Security Header Compliance Matrix

Security Header	Status	Vulnerability	Clear Remediation
Strict-Transport-Security (HSTS)	MISSING	**Man-in-the-Middle (MitM):** Enables hackers to downgrade an encrypted connection from HTTPS to insecure HTTP to intercept login information.	**Enable HSTS:** Forces all connections to remain encrypted by adding Strict-Transport-Security to your server config.
Content-Security-Policy (CSP)	MISSING	**Code Injection (XSS):** Without a CSP, an attacker can inject malicious scripts to steal session cookies or redirect users by executing malicious scripts.	**Implement CSP**: Creates a whitelist of trusted sources for scripts to execute.
X-Frame-Options	MISSING	**Clickjacking:** The hacker might "frame" the GPG website in an evil invisible window in an attempt to trick users into clicking certain buttons	**Set to 'SAMEORIGIN'**: This ensures the website is not framed in an iframe in an external malicious domain.
Server / X-Powered-By	EXPOSED	**Information Leakage**: The server reveals Microsoft-IIS/10.0 and ASP.NET information to hackers in an attempt to research certain exploits	**Suppress Headers:** Configure the web. Config file to remove these version strings from the public response.
X-Content-Type-Options	MISSING	**MIME-Sniffing:** Browsers might try to "guess" the file type, which can lead to a script being executed as an image.	**Set to 'nosniff':** Forces the browser to strictly follow the file types defined by the server.

The Methodology: Passive Reconnaissance

To ensure the safety and stability of the GPG Professional Job Centre portal, I employed the Passive Reconnaissance Framework. Passive Reconnaissance is the process of gathering external intelligence which is broadcast by the server to the public Internet. It is a non-intrusive methodology which does not affect the existing services.